AEGIS SIEM

Analyst User Guide

A practical walkthrough of Excel ingestion, security analysis, findings, dashboards, MITRE ATT&CK® alignment and PDF reporting.

PROJECT DOCUMENTATION • VERSION 1.0 • 31 OCTOBER 2026

Purpose

This document describes the current Aegis SIEM starter application as implemented in the delivered source files. It is intended to help an analyst operate the application, interpret its outputs, and understand its limitations.

Contents

- 1. What Aegis does - and what it does not do
- 2. Launching Aegis on Windows
- 3. Understanding the workspace navigation
- 4. Importing a workbook and mapping columns
- 5. How the analysis engine works
- 6. Reading risk scores and severity
- 7. Understanding MITRE ATT&CK® alignment
- 8. Working through the PDF report
- 9. Language, appearance and exports
- 10. Data handling, troubleshooting and safe use
- 11. Quick analyst checklist

1. What Aegis does - and what it does not do

Aegis SIEM is a local-first, single-user security analytics workbench for reviewing SIEM log exports saved as Excel workbooks. It accepts an .xlsx or .xls file, suggests mappings from the workbook columns to a normalized event schema, applies explainable heuristic rules, and presents the result in a SOC-style workspace. The application can export filtered events, findings, and a structured technical PDF report.

Aegis is designed to help an analyst triage a dataset, not replace an enterprise SIEM, endpoint detection platform, incident-response team, or full forensic workflow. It does not continuously ingest events, query a live SIEM, perform threat-intelligence lookups, or prove that a system has been compromised.

> **Core operating principle**
>
> Aegis identifies patterns in the data that was uploaded. The result is only as complete and reliable as the workbook, field mappings, timestamps, units, and telemetry supplied by the analyst.

Main capabilities

- Read Excel-based security events from one selected worksheet.
- Suggest column mappings and let the analyst correct them before analysis.
- Normalize timestamps, severity values, event categories, and outbound-byte values.
- Run a configurable set of local detection rules and retain representative event evidence.
- Present aggregate risk, event statistics, findings, filters, and event exploration.
- Show candidate MITRE ATT&CK technique alignments where the observed fields support a defensible association.
- Generate an English or Spanish PDF report with findings, evidence, explanations, priorities, and actions.

2. Launching Aegis on Windows

The delivered Windows package is configured for 64-bit Python 3.10. The project also includes Python virtual-environment and run scripts. Python 3.10 is selected explicitly so another installed Python version is not accidentally chosen.

First launch

1. Extract Aegis_SIEM_Final_Edition.zip into a folder where your Windows account can write files.

2. Install 64-bit Python 3.10.x and ensure the Python Launcher (py) is installed.
3. Double-click setup_windows.bat once. It creates a .venv folder and installs dependencies from requirements.txt using prebuilt wheels only.
4. When setup reports completion, double-click run_windows.bat.
5. Keep the terminal window open while using Aegis. Open the Local URL printed in the terminal, normally http://localhost:8501, in Chrome or Edge.

Normal launch and shutdown

After initial setup, use run_windows.bat for each session. To stop the local app, return to its terminal window and press Ctrl+C. Closing the browser alone does not necessarily stop the Streamlit process; stop it in the terminal when finished.

```
Local URL:  http://localhost:8501
Stop:       Ctrl + C  (in the terminal window)
```

> **Important**
> localhost means the Streamlit server running on your own computer. If you later deploy Aegis to a server or cloud host, uploaded workbooks will be processed by that host and its administrators may be able to access them.

3. Understanding the workspace navigation

Workspace	What it is for	Typical analyst task
Command Center	Operational overview of the current uploaded dataset.	Start here: review dataset size, overall risk, alert priority, event severity and trends.
Findings	Detection register and detail view.	Choose a finding, read its explanation and evidence, inspect candidate ATT&CK techniques, decide what to validate.
Event Explorer	Searchable table of normalized source events.	Search an IP, user, host, event ID, process or message; filter by severity or detected-only events.
Reporting Center	Report summary and PDF export.	Review the summary and action list, then generate the bilingual technical report.
Data & Rules	Workbook import, worksheet selection, column mapping and analysis controls.	Upload a workbook, confirm the mapping, tune thresholds and execute the analysis.

The navigation buttons switch the visible workspace inside the same browser tab. This is in-place navigation; it does not open a new browser tab for each area. The workbook and analysis are held in Streamlit Session State while the current session remains active.

Sidebar controls

- Language: switches the interface and generated report narrative between English and Spanish. Original event text remains as supplied in the source workbook.
- Appearance: Graphite & Jade, Midnight Blue, or Light Analyst. This changes the UI palette, not the detection results.
- Typeface: Segoe UI (sans-serif), Georgia (serif), or Consolas (monospaced). This is a visual preference only.

- Detection tuning: adjust the failed-login threshold, unique-destination threshold, outbound transfer threshold, and whether vendor High/Critical events should be carried forward as findings.

4. Importing a workbook and mapping columns

Supported file types and worksheet

Aegis supports .xlsx and legacy .xls workbooks. Select the worksheet containing the events you want to analyze. The app does not combine multiple worksheets automatically; analyze the relevant sheet as a defined dataset.

Canonical fields

Aegis field	Meaning / examples	Importance
timestamp	Event time, date/time, @timestamp.	Needed for time charts and time-window correlations.
source_ip	Originating IP, client IP, src.	Used to group authentication activity and network fan-out.
destination_ip	Target IP, dest, dst.	Used for unique-destination fan-out.
username	User, account, principal.	Used to group authentication activity and identify affected accounts.
event_id	Windows/vendor event code or signature ID.	Used for event classification and some rules.
event_name	Event type, signature or rule name.	Supports classification and evidence.
severity	Severity, priority or risk label.	Normalizes vendor severity and optional carry-forward rule.
action	Result, outcome, status or disposition.	Provides supporting context for event classification.
message	Raw log message, description or details.	Important input for pattern matching and evidence.
host	Hostname, asset, endpoint or device.	Useful investigative context.
process	Process or executable name.	Used as supporting text for execution detections.
command_line	Full process command line.	Important for suspicious command and LOLBin patterns.
bytes_out	Outbound bytes, bytes sent or uploaded bytes.	Required for the large-egress threshold; values must be bytes.
country	Country or source geolocation.	Context field; not used directly by the current detection rules.

Column mapping procedure

1. Review the automatic mapping suggestions. Aegis matches normalized column names against known aliases (for example, src_ip, source ip, or IP de origen).
2. Use the mapping selector to correct any wrong or missing assignment. Do not assume that a column called “type” is necessarily an event name or that a number called “bytes” is outbound bytes.
3. At minimum, map a useful event/message field (event ID, event name, message, process, or command line) for meaningful detection. Map timestamps and source/user/host fields wherever available.
4. Confirm that bytes_out contains numeric byte counts, not KB, MB, or a vendor-scaled score. Convert the source data before analysis if necessary.
5. Run analysis only after checking the mapping and data-quality notes.

Mapping affects detection coverage

Aegis cannot infer a missing field. If username, source IP, command line or timestamp is not mapped, rules that depend on that field may be less precise or may not run as expected.

5. How the analysis engine works

Processing pipeline

Step	What happens
1. Read	Pandas reads the selected Excel worksheet into a DataFrame.
2. Map	Aegis assigns source columns to its canonical event fields; the user confirms or changes the mapping.
3. Normalize	Timestamps are parsed as UTC; text fields are trimmed; bytes_out is parsed as a number; severity is normalized; a combined event_text is built; a broad event category is assigned.
4. Detect	The enabled heuristic rules scan normalized rows and create findings with severity, description, explanation, recommendation, affected entities, timestamps and representative evidence.
5. Enrich	Aegis adds candidate ATT&CK technique metadata where the matched rule and supporting text justify it.
6. Score	The finding weights are aggregated and capped at 100 to produce an overall risk level.
7. Present / report	The workspace renders dashboard views, filtered tables, CSV downloads and an analyst-oriented PDF report.

Current detection rules

Rule ID	What triggers it	Default / severity	Important limitation
AUTH-BURST	Failed authentication events grouped by available source IP and username. At least the configured number occurs within 10 minutes. If timestamps are not usable, a count-based fallback can flag the group.	8 failures; High.	A repeated failure pattern may be caused by a misconfigured service or stale credentials; it is not proof of brute force.
AUTH-SUCCESS-AFTER-FAIL	A successful authentication has at least 3 related failed attempts in the previous 30 minutes. It filters by source IP and/or username when those values are present.	3 prior failures; Critical.	It is a simple correlation over the export, not a full identity/session correlation.
EXEC-SUSPICIOUS	Command text matches encoded PowerShell, download cradles, selected download utilities, LOLBins, credential-dumping keywords, or shadow-copy/backup deletion commands.	High by default; credential-dumping and backup-deletion indicators are Critical.	Many utilities are dual-use. The pattern match is a lead for process-tree and authorization review.
DEFENSE-EVASION-LOG-CLEAR	Event text matches log-clear patterns such as Windows Security Event ID 1102 / System Event ID 104 with log-clearing wording.	Critical.	Validate the event source and exact log affected; vendor messages may differ.

Rule ID	What triggers it	Default / severity	Important limitation
IDENTITY-PRIVILEGE	Event IDs 4672, 4728, 4732, 4756 or matching privileged access/group-change text.	Medium.	4672 indicates special privileges assigned; it does not by itself prove a group-membership change.
NETWORK-FANOUT	A source IP has at least the configured number of unique destination IPs in the supplied worksheet.	20 unique destinations; High.	Counts the whole export; no fixed time window, port scan or connection outcome is evaluated.
DATA-LARGE-EGRESS	A row has bytes_out greater than or equal to the configured MB threshold converted to bytes.	100 MB; High.	Volume alone cannot establish data theft; destination, process, protocol, sensitivity and baseline are needed.
VENDOR-HIGH-SEVERITY	An event has normalized vendor severity High/Critical and is not already covered by a more specific local detection.	Enabled by default; High or Critical according to source labels.	Severity scales vary by vendor; inspect the originating alert and its evidence.

How a finding is assembled

Each finding receives an identifier such as F-001 and stores a rule ID, title, severity, description, technical explanation, recommended action, representative evidence (up to five event rows), source/user lists, affected label, occurrence count, first/last timestamps, score weight, and optional ATT&CK metadata. Event rows are tagged with the finding IDs that matched them, which makes the Event Explorer “Detected only” filter useful.

6. Reading risk scores and severity

Finding severity vs overall risk

Finding severity describes the priority assigned by a specific detection rule. Overall risk is a separate aggregate score built from the findings that the current analysis generated. It is not the average severity of all workbook rows, and it is not a probability of compromise.

Finding severity	Base points per finding	General interpretation
Critical	30	Urgent analyst review; potential high-impact security control or account issue.
High	22	Prompt investigation and corroboration.
Medium	13	Validate change/activity and business context.
Low	6	Review as part of routine triage.
Other / unrecognized	4	Fallback point value.

Risk score formula

```
volume_factor = min(1.7, 1 + log10(max(1, occurrences)) * 0.18)
finding_weight = severity_points * volume_factor
raw_score = sum(finding_weight for each finding)
risk_score = min(100, round(raw_score))
```

The score is rounded to the nearest integer and capped at 100. If several rules overlap on the same events, each finding still contributes a weight, so the aggregate can reach 100 quickly. It is a prioritization heuristic, not a calibrated severity probability or financial risk measure. ATT&CK mappings do not add or subtract risk points.

Aggregate score	Displayed level
0	Informational
1-24	Low
25-49	Medium
50-74	High
75-100	Critical

Interpret the score in context

A score of 0 means the enabled rules did not create a finding from this workbook. It does not mean the environment is safe. A score of 100 means the heuristic sum hit its cap, not that compromise is certain.

7. Understanding MITRE ATT&CK® alignment

Aegis adds candidate technique alignments from the official MITRE ATT&CK® Enterprise knowledge base. The mapping is attached to selected rule findings and is intended to provide a common behavioral vocabulary for triage. It is not attribution, proof of adversary behavior, or a verdict that an incident occurred.

The mapping is local and deterministic: the application checks the rule ID, finding title, event text and selected event IDs, then returns matching technique records with the technique ID, name, tactic(s), official URL and a rationale/caveat. The mapping does not query MITRE during each analysis and does not alter the Aegis risk score.

Technique coverage included in this version

Technique ID / name	Tactic(s)	Aegis signal and caution
T1110.001 - Password Guessing	Credential Access	Repeated failed logons / successful logon after failures. Candidate only; it does not specifically identify Password Spraying (T1110.003).
T1059.001 - PowerShell	Execution	PowerShell command or script execution patterns.
T1027.010 - Command Obfuscation	Stealth	Encoded or transformed PowerShell command pattern.
T1105 - Ingress Tool Transfer	Command and Control	Script or utility-based content retrieval pattern.
T1197 - BITS Jobs	Persistence; Defense Evasion; Execution	BITSAdmin transfer syntax; legitimate software/update activity also uses BITS.
T1218.005 - Mshta	Stealth	mshta.exe reference; command arguments and context require review.
T1218.010 - Regsvr32	Stealth	regsvr32.exe reference; command arguments and context require review.
T1218.011 - Rundll32	Stealth	rundll32.exe reference; command arguments and context require review.
T1059.005 - Visual Basic	Execution	wscript.exe / cscript.exe reference; confirm script type and intent.
T1003.001 - LSASS Memory	Credential Access	Mimikatz, sekurlsa or LSASS keyword indicator; text alone does not prove memory access.
T1490 - Inhibit System Recovery	Impact	vssadmin / wbadmin deletion command pattern; verify outcome and authorization.
T1685.005 - Clear Windows Event Logs	Defense Impairment	Log-clear event or message; validate event source and the log affected.
T1098.007 - Additional Local or Domain Groups	Persistence; Privilege Escalation	Group membership events such as 4728/4732/4756. Event ID 4672 alone is not enough.

Technique ID / name	Tactic(s)	Aegis signal and caution
T1046 - Network Service Discovery	Discovery	Many unique destination IPs; low-specificity because ports/probes/time-bounds are not inspected.

Signals intentionally left unmapped

- Large outbound transfer: volume alone cannot distinguish ordinary backup or synchronization from exfiltration.
- Vendor High/Critical carry-forward: this preserves an upstream vendor severity label but does not describe a specific behavior.
- Privileged logon rights with Event ID 4672 alone: it does not establish the more specific group-membership technique.

Current catalog note

The log-clearing mapping uses the current Enterprise ATT&CK technique T1685.005 - Clear Windows Event Logs. Validate the ID against the live official ATT&CK website when updating or extending the catalog.

8. Working through the PDF report

The Reporting Center generates a structured technical report in the currently selected language. The report is designed to be readable by both technical stakeholders and managers, while keeping technical evidence and caveats visible.

Report section	What it contains / how to read it
Report identification	Report ID, generated time, source workbook and selected worksheet.
Executive metrics	Overall risk score and level, number of events, total findings and Critical/High count.
Executive summary and scope	Concise statement of what was reviewed and the rule-based nature of the analysis.
Dataset overview	Time coverage and normalized vendor-severity distribution.
Field coverage / mapping	Which source columns were mapped to Aegis fields and the proportion of records with available values.
Finding detail	Finding ID/rule, criticality, count, affected entities, first/last seen, summary, technical explanation, representative evidence, candidate ATT&CK alignment and recommended action.
ATT&CK technique register	Distinct candidate techniques with official references and the finding IDs that reference them.
Plan of action	Findings sorted by severity with suggested priority, owner and target timeframe.
Risk model and limitations	Exact heuristic scoring formula, score bands, and technical caveats.

Evidence and report limitations

The report includes up to five representative event evidence strings per finding, not every raw row. Use the Event Explorer or exported CSV when the full set of related records is needed. The suggested target timeframes and owners are triage recommendations, not a contractual SLA or assignment to a named employee. An analyst should validate the report before distributing it as an incident conclusion.

Recommendations to improve report quality

- Provide source, destination, username, hostname, process and command-line fields whenever available.
- Confirm timestamps and time zones; Aegis treats timezone-naive timestamps as UTC.
- Keep a copy of the original source export and record which worksheet and filters were used.
- Enrich major findings with endpoint process trees, identity provider logs, firewall/proxy records and change tickets before declaring compromise.
- Add analyst notes and an actual case/ticket reference outside Aegis if the report is used in an operational investigation; this MVP does not store case workflow.

9. Language, appearance and exports

English and Spanish options change interface labels and Aegis-authored narratives. Original log messages, executable names, usernames, IP addresses and vendor field values are preserved as source data; they are not automatically translated.

Appearance options are presentation only: Graphite & Jade, Midnight Blue and Light Analyst change UI colors; Segoe UI, Georgia and Consolas change typeface. They do not change the PDF styling or detection logic.

Export	Contents
Filtered events CSV	Rows currently visible in Event Explorer after search and filter controls.
Findings CSV	Findings with rule, severity, description, explanation, recommendation, evidence, score weight and ATT&CK fields.
Technical PDF	Formatted report with executive summary, details, evidence, ATT&CK register and action plan.

10. Data handling, troubleshooting and safe use

Session and privacy model

In the delivered local setup, the workbook is processed by the local Streamlit process and the application does not send log content to an external analysis API. Session State retains the uploaded bytes and analysis results across workspace navigation and Streamlit reruns. A browser refresh, closing the session, stopping the server or an application restart can clear session-held analysis; the MVP does not persist cases or datasets to a database.

If the application is later hosted on a network server, local-first assumptions no longer mean “only on your computer”: data is processed by the host and may be accessible to its administrators. Use only approved environments and sanitized/synthetic exports for demonstrations.

Common issues

Symptom	What to check
“Virtual environment not found.”	Run setup_windows.bat once from the extracted project folder. Then run run_windows.bat.
Python not found / wrong version.	Use 64-bit Python 3.10 and the Python Launcher. Run py -0p to view registered interpreters.
Excel file fails to read.	Confirm the file opens in Excel, choose the correct worksheet, close it if locked, and check that its format is .xlsx or .xls.

Symptom	What to check
Few/no findings.	Confirm mapping for message/event ID/name, timestamp, source, user, process and command line. Inspect data quality and thresholds.
Unexpected egress finding.	Confirm bytes_out values are bytes rather than KB/MB; review the configured threshold and the row values.
Time charts look wrong.	Check timestamp mapping and whether timezone-naive timestamps should be interpreted as UTC.
ATT&CK field is empty.	The available event data may not support a specific technique. Some alerts are intentionally left unmapped to avoid overclaiming.

Operational limitations

- Single-user local MVP; no authentication, role-based access control, multi-tenancy or analyst audit trail.
- No persistent case database, evidence chain-of-custody tracking, analyst comments, assignment or status workflow.
- No live SIEM API ingestion, streaming pipeline, enrichment service or threat-intelligence connection.
- No machine-learning model; detections are deterministic heuristics and patterns.
- No claim of complete ATT&CK coverage, no automatic adversary attribution and no guarantee of detection completeness.

11. Quick analyst checklist

- Confirm the source workbook and worksheet are the intended scope.
- Verify the timestamp, message/event ID, severity, username, source IP, host, process, command line and bytes mapping.
- Confirm timestamp timezone and outbound byte units.
- Record the detection threshold settings used for the run.
- Review Critical and High findings first; validate their raw evidence and surrounding context.
- Treat ATT&CK entries as candidate alignments, not confirmed technique use.
- Export the filtered event CSV if full evidence is needed.
- Review the PDF report, caveats and suggested action plan before distribution.
- Preserve the original source export in an approved evidence location.

References and official resources

The following links are official project documentation or framework references. Aegis uses these resources for API behavior, format support, and technique nomenclature; it does not embed or redistribute their full source projects.

[1] Streamlit - Session State. Explains reruns and session-scoped application state.
https://docs.streamlit.io/develop/concepts/architecture/session-state

[2] pandas - read_excel. Documents Excel workbook and worksheet ingestion behavior.
https://pandas.pydata.org/docs/reference/api/pandas.read_excel.html

[3] MITRE ATT&CK® - Legal & Branding. Sets first-reference and no-endorsement branding guidance; official Terms of Use: https://attack.mitre.org/resources/terms-of-use/. https://attack.mitre.org/resources/legal-and-branding/

[4] MITRE ATT&CK® - Clear Windows Event Logs. Official reference for technique T1685.005.
https://attack.mitre.org/techniques/T1685/005/